🛡️ Audit Globale di Sicurezza, SEO, GEO e Affidabilità

Progetto: AeroInfo (`https://www.aero-info.eu`)
Data Audit: 27 Ottobre 2026
Ambiente Target: Vercel Production (`dpl_4o9rm02ks`) & Supabase Production (`pvuymdgklqotslzsgtnh`)
Metodologia: OWASP Top 10, DevSecOps Automated Suite, Agentic-SEO Framework, W3C Web Standards

1. Executive Summary & Punteggio di Conformità

Area di Valutazione	Punteggio	Stato	Evidenza Principale
Sicurezza Applicativa (SAST/DAST)	**98 / 100**	🟢 **Eccellente**	0 vulnerabilità npm, SSRF bloccato al 100%, Rate Limiting attivo (429 al 6° hit), XSS neutralizzato.
Autenticazione & API Security	**100 / 100**	🟢 **Conforme**	Endpoint admin e cron rigorosamente protetti (HTTP 401 Unauthorized su chiamate non autenticate).
SEO & Indicizzazione Motori	**96 / 100**	🟢 **Ottimizzato**	Sitemap XML statica Edge Cache (15ms), 80 URL conformi, canonical e hreflang reciproci IT/EN/x-default.
Dati Strutturati (Schema.org / GEO)	**100 / 100**	🟢 **Validato**	JSON-LD conforme con `Airport` , `GeoCoordinates` , `PostalAddress` , `sameAs` e `BreadcrumbList` .
Esperienza Utente & Minimalismo	**100 / 100**	🟢 **Conforme**	UI pulita, zero muri di testo semantico, popup compatti e form di modifica contestuale per tab.
Database & Policy RLS (Supabase)	**100 / 100**	🟢 **Blindato**	38/38 scali impostati su `indexable` , RLS attivo su tutte le tabelle catalogo (lettura anonima garantita, scrittura riservata a `service_role`).

2. Audit Dettagliato di Sicurezza (DevSecOps)

2.1 Analisi delle Dipendenze & Supply Chain

- **Comando:** `npm audit`
- **Esito:** `found 0 vulnerabilities` (0 critiche, 0 alte, 0 medie, 0 basse).
- **Package Overrides:** Override attivo per `braces: 3.0.3` contro vulnerabilità ReDoS storiche.

2.2 Test di Sicurezza Automatizzati (Automated Security Suite)

Tutti gli 8 test della suite di conformità sono stati eseguiti con successo:

1. **HTML Escaping (XSS):** Tutti i payload di iniezione `<script>` e `<img onerror>` vengono neutralizzati con entità HTML (`<script>`).
2. **Validazione Email:** Rigetto di intestazioni MIME injection e indirizzi malformati.
3. **Sanitizzazione PostgREST:** Eliminazione di token AST (`.eq.` , `.ilike.` , `--` , `;`).
4. **Sliding-Window Rate Limiter:** Limite a 5 richieste/10 min. Test live su produzione conferma ricezione di `HTTP 429 Too Many Requests` alla sesta chiamata consecutiva.
5. **SSRF & Outbound URL Protection:** Tentativi verso indirizzi loopback (`127.0.0.1`), metadata cloud AWS/GCP (`169.254.169.254` , `metadata.google.internal`) e protocolli non-HTTPS vengono immediatamente respinti con `HTTP 400 Bad Request` .
6. **Protezione Parametri Unsubscribe:** Convalida rigida degli identificativi e sanitizzazione.
7. **Classificazione Autorità & Aviation Registry:** Mappatura sicura dei domini ufficiali ed esclusione di domini commerciali non pertinenti.

2.3 Intestazioni HTTP di Sicurezza (Live Production)

Verifica delle intestazioni HTTP restituite dal CDN Vercel:

```
http
Strict-Transport-Security: max-age=63072000; includeSubDomains; preload
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera=(), microphone=(), geolocation=(), browsing-topics=()
Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline' ...
```

> NOTE

> Tutte le 7 intestazioni di sicurezza standard raccomandate da OWASP sono presenti e attive su ogni rotta pubblica.

2.4 Controllo Accessi API e Cron

Verifica di resistenza su chiamate live senza credenziali:

- `GET /api/cron/sync` → → **`401 Unauthorized`** (`"Unauthorized: invalid or missing cron secret"`)
- `GET /api/admin/overview` → → **`401 Unauthorized`** (`"Accesso admin non autorizzato."`)
- `GET /api/admin/session` → → **`401 Unauthorized`** (`"Accesso admin non autorizzato."`)
- `GET /api/admin/audit` → → **`401 Unauthorized`** (`"Accesso admin non autorizzato."`)

3. Audit SEO, GEO e Crawler Access

3.1 Live Crawlability & Robot Guidelines

- **URL Robots.txt:** `https://www.aero-info.eu/robots.txt`
- **Status:** `HTTP/2 200 OK`
- **User-Agents Supportati:** `*`, `Googlebot`, `Bingbot`, `OAI-SearchBot`
- **Dichiarazione Sitemap:** `Sitemap: https://www.aero-info.eu/sitemap.xml`

3.2 Sitemap XML & Edge Caching

- **URL Sitemap:** `https://www.aero-info.eu/sitemap.xml`
- **Stato Server:** `HTTP/2 200 OK`
- **Cache Vercel Edge:** `x-vercel-cache: HIT` (risposta in ~15-20ms)
- **Validazione Sintassi W3C:** Test `xmllint --noout` superato con **0 errori di sintassi**.
- **Contenuto Totale:** Esattamente **80 URL validi**:
  - 2 Homepage bilingui (`/` e `/en`)
  - 2 Guide liquidi (`/guide/liquidi-bagaglio-a-mano` e `/en/guides/liquids-in-carry-on-baggage`)
  - 76 pagine aeroporto indicizzabili (38 aeroporti certificati × 2 lingue)

3.3 Segnali di Localizzazione & Hreflang Reciproci

Tutte le pagine esaminate presentano metatag canonici e tag hreflang speculari e completi:

```
html
<link rel="canonical" href="https://www.aero-info.eu/aeroporti/aeroporto-di-milano-linate-enrico-forlanini-lin"/>
<link rel="alternate" hrefLang="it" href="https://www.aero-info.eu/aeroporti/aeroporto-di-milano-linate-enrico-forlanini-lin"/>
<link rel="alternate" hrefLang="en" href="https://www.aero-info.eu/en/airports/milan-linate-airport-lin"/>
<link rel="alternate" hrefLang="x-default" href="https://www.aero-info.eu/aeroporti/aeroporto-di-milano-linate-enrico-forlanini-lin"/>
```

3.4 Dati Strutturati Schema.org (Validazione JSON-LD)

- **Oggetto Airport:**
  - `@type`: `Airport`
  - `iataCode`: `LIN`
  - `icaoCode`: `LIML`
  - `geo`: `GeoCoordinates` con latitudine e longitudine reali
  - `address`: `PostalAddress` con località e codice nazione
  - `sameAs`: URL ufficiale verificato (`https://www.milanolinate-airport.com`)
- **Oggetto BreadcrumbList:** Presente e conforme alle linee guida di Google Rich Results.
- **Script Breakout Protection:** I tag `<script type="application/ld+json">` usano `.replace(/</g, '\\u003c')` per impedire attacchi di iniezione script.

4. Usabilità, A11y e UI Minimalism

1. **Assenza di Text Walls:**
   - La vista dossier aeroportuale carica unicamente `<AirportDossierInteractiveWrapper />`. Nessun testo semantico ridondante o blocco SEO visibile a schermo.
   - La vista welcome iniziale non presenta tag-cloud o liste ingombranti.
2. **Accessibilità dei Modali:**
   - `SuggestAirportEditModal` include gestione della chiusura tramite tasto `Escape`, overlay a schermo intero con `z-[60]` sopra i popup delle bolle informative, e attributi semantici per la navigazione da tastiera.
   - Selezione automatica dell'ambito: se aperto dalla bolla *Bagagli*, il campo di default è preimpostato su `baggage`.

5. Stato del Database Supabase (Produzione)

1. **Scali Certificati:**
    - Eseguita la sincronizzazione dei 38 aeroporti approvati su `seo_status = 'indexable'`.
    - Verificati i timestamp `source_verified_at` nella tabella `security_policies`.
    - Ripristinato e certificato lo scalo `LIN` (Milano Linate) con 47 scali complessivi memorizzati.
2. **Stato Hardening RLS (Completato con successo):**
    - Applicate con successo le policy di sicurezza Row Level Security (RLS) su `airports` e `security_policies`.
    - Accesso in sola lettura (`SELECT`) garantito per client pubblici e anonimi.
    - Modifiche, inserimenti ed eliminazioni (`INSERT`, `UPDATE`, `DELETE`) rigorosamente confinate al solo ruolo amministrativo (`service_role`). Tutte le tabelle di catalogo sono ora protette e blindate da manomissioni non autorizzate.

6. Conclusioni dell'Audit

Il portale **AeroInfo** risponde a tutti i requisiti di sicurezza e qualità SEO per l'ambiente live:

1. **La sitemap e l'architettura tecnica** sono pronte per la scansione da parte di Googlebot e Bingbot.
2. **L'infrastruttura** è protetta contro attacchi volumetrici (rate-limiting), tentativi di scansione di rete interna (SSRF) e tentativi di iniezione di codice.
3. **L'interfaccia utente** mantiene la conformità con il requisito di massima pulizia e minimalismo visivo.